Northstar Payment Systems, Inc.

GRC Gap Assessment & Risk Register
Project Charter and Assessment Plan

Document Status and Use

This document outlines the fictional business scenario, assessment scope, methodology, and assumptions used in the Northstar Payment Systems GRC assessment. The project includes a completed review of selected simulated evidence, documented control assessments, risk evaluations, and recommended remediation actions. Assessment conclusions are limited to the selected control objectives and available simulated evidence. Framework mappings remain proposed and do not establish formal compliance with NIST CSF 2.0, SOC 2, or PCI DSS.

1. Company Scenario

Northstar Payment Systems, Inc. is a fictional U.S. fintech/payment services provider offering a cloud-based payment processing and transaction management platform to business customers.

- Scenario assumption: approximately 350 employees.
- Scenario assumption: approximately 1,200 business customers.
- Scenario assumption: the platform processes payment-related information and stores or handles customer information.
- Scenario assumption: cloud services and corporate technology systems support the service.

Payment-Environment Assumption:

For this project, Northstar is assumed to receive payment-card data through its payment platform and transmit it to a third-party payment processor. Northstar does not keep card numbers for ongoing storage; however, it keeps transaction metadata and processor tokens. Although card numbers are not stored long-term, their temporary handling remains within the assessment scope. The systems and connections that process this data or could affect its security, must be identified when determining which PCI DSS requirements apply.

These assumptions are placeholders for a realistic learning scenario, not verified facts. Before public release, check whether the company name conflicts with an existing organization and rename it if needed.

Systems and Third-Party Boundaries:

For this assessment, the preliminary system boundary includes Northstar's payment platform, the systems and services used to administer and support that platform, and the corporate systems that could affect the security of the payment environment. These may include identity and access management, privileged administrator accounts, security logging and monitoring, application development and deployment systems, and vulnerability management processes.

The third-party payment processor is treated as an external service provider that receives payment data from Northstar and performs payment processing. The assessment will consider the security responsibilities shared between Northstar and the processor, the information exchanged between them, and the evidence needed to evaluate relevant third-party risks.

The final assessment boundary and applicable PCI DSS requirements must be determined by examining the payment-data flow, system connections, administrative access, and systems that store, process, transmit, or could affect the security of payment account data. The boundary described above is preliminary and based on fictional scenario assumptions; it is not a verified PCI DSS scope determination.

Preliminary Payment-Data Flow

For this fictional scenario, Northstar's payment-data flow is assumed to follow these steps:

1. **Payment initiation:** A business customer initiates a payment through Northstar's payment platform.
2. **Data receipt and temporary handling:** Northstar's platform receives and temporarily handles payment-card data before transmitting it to the third-party payment processor.
3. **Transmission to the processor:** Northstar transmits the payment data to the processor through a connection intended to protect the data in transit.
4. **Payment processing:** The third-party processor performs the payment-processing functions. The processor's internal systems and controls are outside Northstar's direct operational control, but relevant third-party risks and shared responsibilities remain within the assessment's scope.
5. **Transaction records:** Northstar retains transaction metadata and processor tokens for its business operations. Under the scenario assumptions, Northstar does not retain card numbers for ongoing storage.
6. **Security and administration:** Northstar's identity and access management, administrator accounts, application deployment processes, security monitoring, and other connected systems may affect the security of the payment environment and must be considered when determining the assessment boundary.

This flow is a preliminary model based on fictional assumptions. The actual data elements, system connections, token behavior, and security responsibilities have not been independently verified. The flow must be refined before the final assessment scope, and applicable PCI DSS requirements are established.

2. Project Purpose and Objective

Purpose

Demonstrate a structured, evidence-based approach to a cybersecurity Governance, Risk, and Compliance (GRC) gap assessment and risk register using a fictional payment services provider.

Assessment Objectives

The objectives of this project are to:

1. Evaluate selected cybersecurity controls supporting Northstar's payment platform, customer information protection, and payment-processing operations against applicable assessment criteria.
2. Identify gaps between defined control expectations and conditions supported by the available assessment evidence.
3. Evaluate risks associated with identified control gaps, considering potential business impact, likelihood, and existing safeguards.
4. Recommend prioritized remediation actions to address supported control gaps and reduce identified risks.
5. Communicate the assessment approach, results, limitations, and recommendations in a professional report suitable for management review.

Limitations

This project is a fictional portfolio simulation, not a formal audit, independent SOC 2 examination, PCI DSS compliance validation, or certification. All simulated evidence and assessment results will be clearly labeled. Conclusions will be limited to the selected controls, applicable criteria, scenario assumptions, and evidence reviewed.

3. Frameworks and Criteria

Overarching framework: NIST Cybersecurity Framework (CSF) 2.0, used to organize cybersecurity outcomes, assessment activities, and risk communication. It is not used here as a certification or compliance determination.

Focused payment-card criteria: PCI DSS v4.0.1, used only to plan and assess criteria that may apply to the assumed cardholder-data environment (CDE) and related payment data flows. The project does not determine PCI DSS compliance, validate a PCI scope, or represent a Report on Compliance, SAQ, or assessor conclusion.

Service-organization assurance readiness: SOC 2 Trust Services Criteria Security is the default assurance lens for the service. Other criteria are considered only when justified by the stated scope or service commitments. Availability may be considered for recovery or uptime commitments; other categories are not presumed in scope. This project is SOC 2-informed and does not constitute a SOC 2 examination or attestation.

Proposed references link the control inventory to NIST CSF 2.0, PCI DSS v4.0.1, and SOC 2 Security criteria. Current ratings are based on the project's control objectives and selected simulated evidence. Framework mappings and applicability have not been verified and do not establish compliance

4. Proposed Scope

In scope — selected controls supporting the cloud payment service and corporate technology systems that materially affect it:

- Governance and cybersecurity risk management
- Asset inventory, classification, and third-party risk management
- Identity and access management, including privileged access and MFA

- Change management and vulnerability remediation
- Security logging and monitoring
- Incident response
- Protection of sensitive information
- Backup, recovery, and service availability
- Payment transaction integrity

Out of scope:

- Live penetration testing or exploitation of real systems
- Real production systems, credentials, or customer PII
- A full financial statement audit
- A formal SOC 2 examination or attestation
- Certification or definitive determination of regulatory compliance

Scope rationale: prioritize control areas based on plausible business risks to customer information, payment processing integrity, and service availability. A gap assessment can include technical testing when appropriate and authorized; live penetration testing is excluded here because it is outside this project's defined objectives and would require separate authorization, safeguards, and operational planning.

Assessment Boundary and Control Inventory

The assessment used the 12 selected control areas listed in Section 5 as its control inventory. The assessment will focus on the payment platform and the systems, processes, and third-party dependencies that could materially affect its security. The inventory and boundaries may be refined as the assessment criteria and supporting evidence are reviewed.

The precise payment-card environment boundary and applicable PCI DSS requirements have not yet been established. These will require further analysis of payment-data flows, system connections, administrative access, and relevant third-party responsibilities. The project will not assume that temporary handling of payment-card data or the use of processor tokens automatically removes systems from scope.

5. Proposed Control Inventory

ID	Control area	Intent
CTL-01	Security governance and responsibilities	Roles, policies, accountability, and risk oversight
CTL-02	Asset inventory and classification	Identify relevant assets and classify information
CTL-03	Third-party risk management	Assess and monitor suppliers that can affect the service
CTL-04	Access lifecycle and access reviews	Approve, provision, review, and terminate user access
CTL-05	Privileged access and MFA	Restrict privileged access and enforce applicable authentication requirements
CTL-06	Change management	Authorize, test, and document relevant system changes
CTL-07	Vulnerability management	Identify, prioritize, and remediate vulnerabilities

ID	Control area	Intent
CTL-08	Logging and monitoring	Record and review security-relevant events
CTL-09	Incident response	Prepare for, report, investigate, and learn from incidents
CTL-10	Sensitive data protection	Protect sensitive information through appropriate safeguards
CTL-11	Backup and recovery	Back up relevant systems/data and test restoration
CTL-12	Payment transaction integrity	Protect transaction processing and reconcile exceptions

6. Assessment Methodology

The assessment followed a structured, evidence-based methodology to evaluate selected cybersecurity controls within Northstar's defined assessment scope. Each control was evaluated against documented control objectives using available simulated evidence. Assessment conclusions were limited to the evidence reviewed, stated assumptions, and identified limitations.

Step 1: Define the Control Objective and Assessment Criteria

For each control, document its objective, intended outcome, relevant system or process, and applicable assessment criteria. Criteria will be mapped to the selected frameworks where applicable. For this portfolio exercise, conclusions are based on documented control objectives. Framework-specific conclusions require verified mappings and applicability.

Step 2: Identify and Request Evidence

Identify the evidence needed to evaluate each control. Evidence may include policies, procedures, system configurations, account inventories, access-review records, vulnerability reports, security logs, incident records, and backup-recovery test results.

All evidence created for this fictional portfolio project will be simulated and clearly labeled. Each evidence item will have an identifier, source or owner, relevant date or assessment period, associated control, and documented limitations where applicable.

Step 3: Evaluate Evidence

Evaluate the available evidence to determine whether it supports the control's design, implementation, and operation, where applicable.

- **Design:** Determine whether the control is appropriately defined to address the relevant risk and meet the applicable criteria.
- **Implementation:** Determine whether the control has been put in place within the relevant environment.
- **Operation:** Determine whether evidence demonstrates that the control operated as intended during the relevant assessment period.

The evaluation will consider the relevance, completeness, reliability, and period of the evidence. A policy or management statement alone will not automatically establish that a control has been implemented or operated effectively.

Step 4: Identify Gaps and Evidence Limitations

Compare the conditions supported by the evidence against the applicable assessment criteria. Document any identified deviations, exceptions, or weaknesses, along with the supporting evidence.

Where evidence is missing or insufficient, record the limitation and identify any follow-up evidence needed. Missing documentation alone will not automatically be treated as proof that a control failed. However, the absence of required evidence may prevent the assessment from verifying whether the control meets its intended outcome.

Step 5: Assign an Assessment Status

Assign a status using the project's defined rating methodology. The status must reflect the evidence reviewed and the applicable criteria.

The project will distinguish control-performance ratings from evidence sufficiency. An inability to verify a control because evidence is insufficient will be recorded separately from a conclusion that the control does not meet the applicable criteria.

Step 6: Document Findings and Risk Implications

For each supported gap, document the affected control, applicable criteria, condition identified, supporting evidence, potential business impact, and recommended corrective action.

Assess the associated risk using the project's defined risk-scoring methodology. Distinguish inherent risk from residual risk and document the assumptions and existing safeguards supporting each assessment. Residual risk will not be represented as verified unless the evidence supports the conclusion.

Step 7: Develop and Prioritize Recommendations

Recommend practical remediation actions that address the identified gap and its underlying cause. Prioritize recommendations according to the assessed risk, business impact, and remediation needs. Where appropriate, document a proposed owner, target timeframe, and method for validating remediation.

Assessment Limitations

This is a fictional portfolio simulation using simulated evidence, not a formal audit, independent SOC 2 examination, PCI DSS compliance validation, or certification. Control ratings, findings, and risk conclusions were developed using the documented control objectives and selected simulated evidence. Conclusions remain subject to the stated assumptions, evidence limitations, and unverified framework mappings.

Each control will be assessed against its documented objective and applicable assessment criteria. Ratings will be based on the evidence reviewed, the scope of the control, and the limitations identified during the assessment.

- **Met:** Sufficient, relevant evidence supports the conclusion that the control meets the applicable assessment criteria within the defined scope.
- **Partially Met:** Evidence demonstrates that the control is implemented or operating in part, but one or more applicable criteria are not fully satisfied, or a supported deficiency limits the control's effectiveness.
- **Not Met:** Sufficient evidence establishes that the control is absent, not implemented, or fails to satisfy the applicable assessment criteria.
- **Insufficient Evidence:** The available evidence is inadequate to determine whether the control meets the applicable assessment criteria. This status indicates an evidence limitation and does not, by itself, establish control failure.

Rating Rules

1. Ratings must be supported by documented evidence and linked to the applicable assessment criteria.
2. A policy or management statement alone does not automatically demonstrate that a control has been implemented or operates effectively.

3. Missing evidence must not automatically be treated as proof that a control failed. Where evidence is insufficient, document the limitation and pursue appropriate follow-up where feasible.
4. Where evidence establishes a control deficiency, document the affected criterion, the observed condition, and the supporting evidence.
5. Where a control satisfies some criteria but not others, document the specific deficiencies supporting a Partially Met rating.
6. The rationale for each rating must be recorded in the control assessment matrix.
7. Insufficient Evidence must remain distinguishable from control-performance ratings in reporting and analysis. Any aggregate scoring or treatment of evidence limitations will be defined separately before results are summarized.

These ratings are project-defined assessment conventions. They do not, by themselves, establish formal compliance with NIST CSF 2.0, PCI DSS, or SOC 2.

8. Risk Scoring Methodology

The project uses a 5 × 5 risk matrix to evaluate the risks associated with identified control gaps. Each risk scenario will receive a likelihood score and an impact score from 1 to 5.

Risk Score = Likelihood × Impact

The resulting score will range from 1 to 25 and will be assigned a project-defined risk level:

- **Low:** 1–4
- **Moderate:** 5–9
- **High:** 10–16
- **Critical:** 17–25

These thresholds are defined for this portfolio project and are not presented as requirements mandated by the selected frameworks.

Likelihood Assessment

Likelihood will be evaluated using the available evidence and documented assumptions concerning the risk scenario. Relevant considerations may include exposure, existing safeguards, threat conditions, known weaknesses, and the circumstances under which the event could occur.

The project defines a consistent 1–5 likelihood scale before scoring individual risks. Where evidence is limited, the uncertainty and assumptions affecting the score will be documented.

Impact Assessment

Impact will be evaluated according to the plausible consequences of the risk scenario for Northstar. Considerations may include confidentiality, integrity, service availability, payment processing, customer information, operational disruption, and relevant business or contractual obligations.

The project defines a consistent 1–5 impact scale before scoring individual risks. Scores must be supported by the scenario, available evidence, and documented assumptions.

Inherent and Residual Risk

Inherent risk represents the assessed risk before accounting for the relevant safeguards being considered in the analysis. Residual risk represents the remaining risk after accounting for existing safeguards supported by the available evidence.

Planned remediation actions will not be treated as existing safeguards when determining residual risk. Residual risk conclusions will be qualified where the effectiveness of safeguards cannot be established.

Risk Documentation

For each risk, document:

- Risk identifier and associated control.
- Risk scenario and potential business consequences.
- Supporting evidence and identified control gap, where applicable.
- Likelihood and impact scores with rationale.
- Inherent risk score and level.
- Existing safeguards considered.
- Residual risk score and level, where supportable.
- Recommended treatment and remediation actions.
- Relevant assumptions, evidence limitations, and proposed owner or target timeframe where appropriate.

Risk scores are structured assessment estimates, not precise predictions. They will be used to support consistent prioritization and communicate risk, not to imply certainty where the evidence does not support it.

Likelihood Scale

Score	Rating	Definition
1	Rare	The risk scenario is highly unlikely under the assessed conditions. Available evidence indicates limited exposure and effective safeguards.
2	Unlikely	The scenario is possible but not expected to occur frequently. Exposure is limited, and relevant safeguards appear generally effective.
3	Possible	The scenario could occur under plausible conditions. Some exposure or control weaknesses may exist, or the available evidence leaves meaningful uncertainty.
4	Likely	The scenario has a strong possibility of occurring because of significant exposure, known weaknesses, or insufficient safeguards.
5	Almost Certain	The scenario is expected to occur or recur under the assessed conditions, supported by compelling evidence of exposure or repeated occurrence.

Impact Scale

Score	Rating	Definition
1	Negligible	Limited disruption or harm, with minimal effect on business operations or information security.

Score	Rating	Definition
2	Minor	Limited operational disruption or information-security consequences that can be addressed through routine corrective action.
3	Moderate	Meaningful disruption, security consequences, or recovery effort affecting a business process or relevant system.
4	Major	Significant disruption, substantial compromise of sensitive information, or serious interference with payment operations.
5	Severe	Potentially extensive compromise of sensitive information, major disruption to payment services, or severe consequences for Northstar and affected customers.

Scoring Guidance

Likelihood and impact must be assessed separately for each risk scenario. Scores must include a brief rationale based on available evidence, the defined scenario, and documented assumptions.

These scales are project-defined assessment conventions. They are not presented as rating scales mandated by NIST CSF 2.0, PCI DSS, or SOC 2. Where evidence is insufficient to support a confident estimate, the uncertainty must be documented rather than concealed by an apparently precise score.

9. Evidence and Data Handling

- Use synthetic identities, account records, transactions, logs, tickets, and configuration exports.
- Do not include real customer PII, credentials, secrets, or real production data.
- Label every artifact clearly as simulated and assign a stable evidence ID.
- Record artifact owner/source (fictional role/system), creation date, period covered, related control(s), and limitations.
- Keep evidence conclusions proportionate to what each artifact actually proves.

10. Planned Deliverables

- Project Charter & Assessment Plan (this document)
- Control Assessment Matrix and framework mapping
- Evidence Register and simulated evidence package
- Control gap assessment and findings
- Risk Register
- Risk heat map and prioritized remediation roadmap
- Executive summary and final assessment report
- Portfolio README and interview talking points

11. Project Sequence

1. Finalize charter, scenario assumptions, scope, and exclusions
2. Finalize methodology, evidence rules, control ratings, and risk scoring
3. Map framework criteria and finalize control inventory
4. Create simulated evidence artifacts and evidence register
5. Assess controls and document gaps/findings
6. Build risk register and remediation priorities
7. Prepare heat map, roadmap, executive summary, and report

8. Perform quality review and verify traceability
9. Publish portfolio materials after checking naming and accuracy

12. Assessment Planning Considerations

- Confirm final company name and scenario assumptions.
- Define system boundaries and key fictional systems/data flows.
- Finalize control rating definitions and evidence sufficiency rules.
- Define likelihood and impact anchors and risk scoring guidance.
- Select and verify the specific NIST CSF 2.0 outcomes and SOC 2 criteria mapped to each control.
- Define the assessment period and sampling approach, where relevant.

13. Decision Log

Date	Decision / item	Status / note
2026-10-23	Use Northstar Payment Systems, Inc. as a fictional fintech/payment provider	Fictional scenario assumption; no real organization or operations represented
2026-10-23	Use NIST CSF 2.0 as primary framework and relevant SOC 2 criteria as secondary references	Selected; framework mappings remain proposed and unverified
2026-10-23	Use simulated evidence only	Project rule
2026-10-23	Define four control assessment statuses and a 1–5 likelihood/impact scoring methodology. and 1–5 likelihood/impact scoring	Finalized; four control statuses, and 1-5 likelihood/impact scoring defined in Sections 7-8
2026-10-23	Use NIST CSF 2.0 as overarching framework, PCI DSS v4.0.1 as focused payment-card criteria, and SOC 2 Security for assurance readiness	Selected approach; mappings and applicability remain proposed pending verification
2026-10-23	Define an assumed CDE, payment data flow, and connected-system boundary	Assumed CDE and payment-data flow documented; actual PCI DSS scope and system boundaries not validated
2026-10-23	Use SOC 2 Availability only when supported by an explicit service or recovery scope rationale	Conditional; other Trust Services Criteria not presumed in scope

14. Framework Approach and Proposed Mapping Rules

NIST CSF 2.0 is the overarching framework for organizing governance, risk, protection, detection, response, and recovery work. PCI DSS v4.0.1 is the focused payment-card criteria set for the assumed CDE and associated payment flows. SOC 2 Trust Services Criteria Security supports service-organization assurance readiness for the described service.

The project workbooks use proposed framework references for traceability. These references require verification against authoritative materials and a validated system/data-flow scope before supporting any framework-specific assessment or compliance conclusion.

SOC 2 Security is used by default. Availability may be added only where the final scenario includes a specific availability commitment, recovery objective, or service-level obligation that needs to be evaluated. The Confidentiality, Processing Integrity, and Privacy criteria are not included by default and require a documented scope rationale before they are used.

15. Scenario Assumptions and Boundaries

Assumed cardholder-data environment

For this fictional scenario, Northstar's payment platform is assumed to receive and temporarily handle payment-card data before transmitting it to an external processor. The payment API, processor connection, and supporting systems that could affect payment-data security are considered when assessing relevant risks. This is an assumed assessment boundary, not a validated PCI DSS scope determination.

Assumed payment data flow

A customer initiates a payment through Northstar's platform. The payment API temporarily handles payment-card data and sends it to the processor for authorization. Authorization results and transaction references return to Northstar and support reconciliation, exception handling, and customer support.

Northstar is assumed to retain processor tokens and transaction metadata rather than card numbers for ongoing storage. The use of tokens does not, by itself, establish that systems are outside PCI DSS scope.

Assumed connected systems

Potentially relevant systems include cloud infrastructure, identity and access management, privileged accounts, CI/CD and change-management services, vulnerability scanning, centralized logging, incident-management tools, backup and recovery services, and support or payment-operations access.

These systems are considered where they could affect the security or operation of the assumed payment service. The supplied evidence does not establish a complete inventory or verified connectivity boundary.

Boundary exclusions

The assessment excludes real production environments, credentials, customer or cardholder data, merchant environments, payment-network infrastructure, and corporate systems without a relevant connection to the assumed payment service.

The external processor's internal systems and control operation are also excluded. Simulated vendor inventory and action records were reviewed to evaluate Northstar's oversight of external dependencies. Actual provider assurance reports, contracts, and technical integrations were not independently validated.

Applicability and scope assumptions

The assessment uses an assumed fictional payment-service boundary and the connected systems represented in the supplied records. Complete system coverage, data flows, administrative access, service-provider responsibilities, and evidence populations have not been independently validated.

The objective-based review of the supplied simulated evidence is complete. Ratings apply to those samples; PCI DSS and SOC 2 applicability remain proposed.

16. Assessment Status and Evidence Guardrails

The Northstar GRC assessment has been completed as an educational portfolio simulation. The assessment includes a review of selected simulated evidence, documentation of control gaps, evaluation of associated cybersecurity risks, and development of prioritized remediation recommendations.

All findings and risk ratings are based on fictional organizational assumptions and the evidence represented in the project. Findings are limited to the selected control objectives and simulated records reviewed. Framework mappings remain proposed and do not represent formal SOC 2 attestation, PCI DSS compliance validation, or independent audit conclusions. Recommended remediation actions are proposed improvements and are not represented as completed or verified.